

Types of active and passive attacks

DATE / /
PAGE

Active attacks involve an attacker directly interacting with a system to alter or change data, disturbs services or gain unauthorized access is called active attack.

- (a) DOS: Denial of Service
- (b) Malware → Malicious Software
- (c) Phishing
- (d) Spoofing
- (e) injection attack (SQL, XSS)
- (f) Man in the middle
- (g) replay attack

→ Phishing: Attacker steal sensitive information from user via fake email and websites.

→ Spoofing: Attackers impersonate a trusted entity (IP address, email, website) to trusted users.

→ SQL injection: SQL injection is a code injection technique that might destroy your database. SQL injection is one of the most common web hacking techniques.

→ Virus: A virus is a malicious program that attaches itself to a legitimate file or program it activates when infected file is executed.

→ Needs user action to work like opening a file, running a program.

→ Replicates by inserting its code into other files.

→ Spread through USB drives, email attachments or pirated software.

Affects: → Corrupts or deletes files,
→ Slow down the system
→ or may crash the OS.

Example: ... 1300L sector virus
File infection virus

Worm → A worm is a standalone malware that spreads automatically over networks without human interaction.

Affects: Consumes network bandwidth
Causes system slow down or crashes

Example; SQL Slammer

→ Trojan Horse: A trojan pretends itself as a legitimate and useful program but perform malicious action in the background.

User install it believing as genuine it does not replicate like viruses or worms.

Examples; Banking Trojan- Remote Access Trojan (RATs)

→ Ransomware

Encrypts a victim data and demands payments to restore access, they can enter via phishing, emails or malicious downloads.

They have strong cryptography algorithms.

→ Spyware

→ Secretly monitors user activity and collect personal information.

→ Steals login credentials, tracks browsing habits and

sends data to attackers.

→ Installed with free software or via malicious DATE / /
PAGE Link.

→ Runs silently in the background

→ Keyloggers, Loggers.

→ Adware → Browser hijackers

CnC → Command and control

→ Bot: A bot is an infected computer controlled remotely
a bot net is a network of such systems.

→ Logic Bomb

→ Rootkit: A rootkit is designed to hide malware activity and give attacker privilege to access the system. It modifies OS components, conceal files and processes.

→ Principle Information Security Management

The core principle of information security management focus on protecting the CIA i.e confidentiality, integrity and availability of information assets while managing risks efficiently.

Key principles of information security management are

1. Confidentiality: This principle ensures that sensitive information is accessible only to authorized individuals.

2. Integrity: Involves maintaining the accuracy and completeness of information that integrity involves

maintaining the information with accuracy of information it ensures that data is not altered or tampered by unauthorized users.

3. Availability: This principle ensures that information and resources are accessible to authorized users when needed.

4. Risk Management: Effective information security management involves identifying, assessing and investigating risk to information assets.

Example; Target Data Breach

Time Line and Scope

Breach happened during 2013 Holiday Shopping season mid-December.

Hackers gained unauthorized access to Target network and infect point of sale (POS) system with malware to steal card data.

About 40 millions credit and debit card numbers were stolen.

Additionally, names, phone numbers, emails and other personal information of 70 million customers were compromised. Malware used in the target breach was Black POS.

It is a type of malware designed to steal card data from retail systems.

It targets the movement when a credit or debit card is swiped → RAM scrapping.

Cybersecurity Management

Security management is the process of protecting an organization's information asset through planning, implementing, monitoring and improving security measures.

It focuses on (people + process + technology).

The main goal of security management is

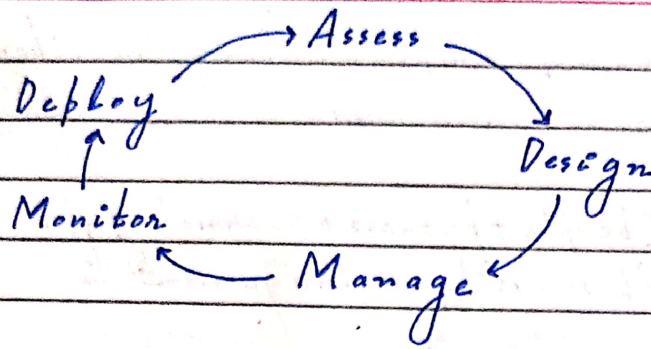
1. protect data from threats.
2. Reduce risk
3. Ensure business continuity
4. Follow legal and regulatory requirements.

=> Key functions of Security Management

Area	What it does?
1. Policy Management	Create rule for using IT system securely.
2. Risk Management	Identify and reduces security risk.
3. Access Control	Ensures only authorized users get access.
4. Incident Management	Handle cyberattack and breaches
5. Security awareness	Train employees about cyberthreat.
6. Monitoring and auditing	Tracks system activity

Lifecycle of Information Security

DATE / /
PAGE



- Assess → Understand the current security situation. In this stage the organization identifies asset, find threats and vulnerabilities and perform risk assessment.

Goal: To know what needs protection and where the risks are?

Design

- Plan the security solutions.
- Security policies are created
- Security architecture are planned
- Controls like firewall, encryption, access control are designed.
- Goal: security blueprint

Manage

- Managing user access
- Applying patches and updates
- Handling security tools
- Enforcing policies

Monitor

- Watch for threats and unusual activity.
- Log in monitoring

- Intrusion detection
- Security Audits
- Performance Check

Deploy

Implement security controls in the real environment

- Here the organization install security tools.
- Applies configuration
- Rollout new policies
- Implement updates

→ GRC in cybersecurity

G → Governance

R → Risk Management

C → Compliance

- Governance defines who is responsible for security and how decisions are made. It includes security policies, roles and responsibilities, leadership oversight security strategy.

- Risk management is the continuous process of identifying, analyzing, evaluating, treating and monitoring risks to keep them at an acceptable level for the business.

Notice the key phrase: acceptable level

- Compliance is the process by which an organization ensures that it follows all applicable laws, regulations, standards and internal policies to operate legally and ethically.

Contingency and Planning (CP)

Contingency Planning refers to preparing in advance to handle unexpected events like

1. Cyberattacks
2. System Failures
3. Natural disasters

so that damage is minimized and operations can continue smoothly.

It ensures an organization is ready to respond, recover and resume critical services.

Objectives of CP

1. Minimize data loss
2. Reduce down time
3. Protect critical system
4. Ensure quick recovery
5. Maintain business continuity

Steps of CP

1. BIA → Business Impact Analysis
 - (i) Which work is important?
 - (ii) How badly will the business suffer?
 - (iii) How fast it be restored?

2. Risk assessment

Malware attacks, insider threats, hardware failure.

3. Incident response plan (IRP)

Detection and recovery

4. Disaster Recovery plan

5. Business Continuity plan

Cyber attack/Disaster



Response Plan Activated

Damage contained

System Recovery

Business operations Resume

Regulatory Landscape

- ① The regulatory landscape refers to the set of laws, rules and policies and guidelines that govern how organization, industries or activities operate within a country or globally.
- ② Regulatory Landscape means the overall framework of regulations, authorities and compliance requirements that effect a particular industry.

Key components of regulatory landscape

1) Laws and acts

Formal legislation passed by government.
For example, environmental laws, IT laws, health regulation etc.

⇒ Regulatory authorities

Government agencies responsible for enforcing rules.

3) Policies and Guidelines

4) Compliance requirements

5) Enforcement mechanisms

US Regulatory Frameworks :

system of laws, regulations and government agencies that oversee and control different sectors of economy and society and the United States.

Structure of the US Regulatory Frameworks

1. Legislative Branch : The United States Congress creates laws that establish regulatory policies and authorized agency to enforce them.

2. Executive Branch : Government agencies develop detailed rules and regulations and enforce them is called executive branch and regulatory agencies.

Ex- Food and drug administration, environment protection agency, security and exchange commission.

3) Judicial Branch: The Supreme Court of United States and other federal courts interpret regulations and resolve disputes related to regulatory actions.

29/03/26

Understanding Security Policy

A security policy is a document that explains how to keep information and systems safe.

Objectives of Security Policy

1. Protect confidential data
2. Prevent unauthorized access
3. Maintain system integrity
4. Ensure availability of information
5. Reduce cyber risks

Elements of a security policy

- i) Access control policy
- ii) Password policy
- iii) Network Security policy
- iv) Data Protection Policy
- v) Incident Response policy

Security Behaviour in Cybersecurity

Security Behaviour means how people act to keep digital information safe